

Received 23 April 2025, accepted 24 June 2025, date of publication 7 July 2025, date of current version 14 July 2025.

Digital Object Identifier 10.1109/ACCESS.2025.3586278

RESEARCH ARTICLE

Automating IoT Data Privacy Compliance by Integrating Knowledge Graphs With Large Language Models

KELVIN U. ECHENIM¹, (Graduate Student Member, IEEE),
AND KARUNA P. JOSHI², (Senior Member, IEEE)

Department of Information Systems, University of Maryland, Baltimore County, MD 21250 USA

Corresponding authors: Kelvin U. Echenim (kelvine1@umbc.edu) and Karuna P. Joshi (karuna.joshi@umbc.edu)

This work was supported by National Science Foundation (NSF) Award 2310844 titled Phase II IUCRC University of Maryland, Baltimore County (UMBC): Center for Accelerated Real-time Analytics (CARTA).

ABSTRACT Regulatory compliance is mandatory for Internet of Things (IoT) manufacturers, particularly under stringent frameworks such as the General Data Protection Regulation (GDPR), which governs the handling of personal data. We introduce a novel framework for automating IoT compliance verification by integrating a Large Language Model (LLM) with a domain-specific Knowledge Graph (KG). The framework achieves two primary objectives: 1) leveraging the LLM to interpret natural-language compliance queries, and 2) employing a KG populated with synthetic GDPR scenarios to provide structured, up-to-date regulatory guidance, modeling obligations, permissions, and prohibitions for both deontic (normative) and non-deontic (factual) queries, thus mitigating biases and hallucinations inherent in language models. Evaluated on 50 representative GDPR compliance queries, our approach achieves high semantic alignment (mean BERTScore F1 of 0.89), with expert reviewers rating approximately 84% of generated compliance advice as fully or mostly correct. This work offers IoT manufacturers a scalable, automated solution for data privacy compliance.

INDEX TERMS Data privacy compliance, IoT, knowledge graphs, large language models, regulatory compliance automation, semantic interoperability, wearables.

I. INTRODUCTION

Technology and data governance are undergoing momentous transformations as the IoT era progresses. IoT devices, such as smart home systems and wearable health monitors, are becoming more prevalent daily, raising concerns about data privacy and regulatory compliance [1]. The General Data Protection Regulation (GDPR), for instance, imposes strict obligations on the processing of personal data, requiring IoT manufacturers to adhere to principles such as lawfulness, fairness, transparency, and purpose limitation [2]. However, maintaining compliance remains a formidable challenge, especially given the intricate and dynamic nature of regulatory requirements.

The associate editor coordinating the review of this manuscript and approving it for publication was Chang Choi³.

Traditional approaches to automating regulatory compliance, such as rule-based systems and machine learning models, have several shortcomings. Rule-based systems are inherently rigid and necessitate constant manual updates to reflect changes in regulatory frameworks. Similarly, while machine learning models are scalable, they often operate as black boxes, lacking the transparency and explainability required to justify their outputs in regulatory contexts [3]. In the next section, we explore some recent studies that have examined the integration of Large Language Models (LLMs) and Knowledge Graphs (KGs) to address these limitations. LLMs excel at natural language processing and interpretation and have established capabilities in translation, question answering, and text generation tasks [4]. KGs, in contrast, provide structured, machine-readable representations of regulatory rules. Despite their promise, existing approaches

fail to address IoT-specific challenges, particularly those requiring deontic reasoning about obligations, permissions, and prohibitions—critical elements for ensuring compliance with strict frameworks like the GDPR.

This work presents a novel framework for automating IoT data privacy compliance by integrating KGs with LLMs. Given that contemporary data is convoluted by nature, constructing comprehensive and accurate KGs is a significant challenge [5]. Our *IoT-Reg* KG [6], adopted for this study, models GDPR obligations, permissions, and prohibitions throughout the IoT data lifecycle. We incorporate deontic logic into the KG and fine-tune an LLM to generate SPARQL queries from natural language questions, as the framework supports factual (non-deontic) and normative (deontic) compliance queries. This unification offers IoT manufacturers an efficient and scalable tool for meeting regulatory requirements.

The contributions of this work include the development of a unified compliance framework that leverages the interpretive power of LLMs and the structured precision of KGs to automate GDPR compliance checks for IoT devices. The *IoT-Reg* KG explicitly incorporates deontic logic, allowing for a greater compliance reasoning depth. Combining the strengths of LLMs' advanced natural language processing capabilities with the structured knowledge representation of KGs results in a more flexible and reliable system [7]. This synergy fills gaps in existing compliance-checking mechanisms and can significantly improve the reliability and efficiency of IoT compliance processes, enabling near-real-time decision-making support. Our evaluation encompasses various IoT compliance scenarios demonstrating the system's ability to deliver semantically accurate and actionable advice.

The rest of this paper is structured as follows: Section II reviews related work and background on the theoretical foundations in regulatory compliance automation, LLMs, and KGs. Section III outlines the proposed methodology, and Section IV describes the experimental setup. Section V summarizes the evaluation and results, while Section VI discusses challenges and future work. Finally, Section VII concludes the paper.

II. RELATED WORK AND BACKGROUND

A. LLMs IN REGULATORY COMPLIANCES

LLMs are pre-trained language models built upon the transformer architecture, consisting of feed-forward neural networks, normalization layers, positional encoders, and self-attention mechanisms. These transformers employ an encoder-decoder framework adept at processing sequential input data autoregressively. The encoder part maps the input sequence to a higher-dimensional space, capturing the context of each element within the sequence. Meanwhile, the decoder generates output based on this encoded information. The self-attention modules within transformers enable it to focus on relevant parts of the data when making predictions, allowing the model to weigh the importance of different words in the input sequence [8].

LLMs are based on probability distribution. For a sequence of words, $w_1, w_2, \dots, w_n$, the probability of the sentence S (the sequence of words) can be expressed using the conditional probabilities chain rule, which considers the likelihood of each word given the previous words in the sequence [9].

$$P(S) = P(w_1) \cdot P(w_2|w_1) \cdot P(w_3|w_1, w_2) \cdot \dots \cdot P(w_n|w_1, w_2, \dots, w_{n-1}).$$

More generally, for a sequence of n words,

$$P(w_1, w_2, \dots, w_n) = \prod_{i=1}^n P(w_i|w_1, w_2, \dots, w_{i-1})$$

In regulatory compliance applications where complex patterns in laws and standards must be understood, this probabilistic formulation is advantageous as it allows LLMs to generate coherent sequences. In recent studies, for example, there has been a growing use of LLMs in regulatory compliance, with applications including horizon scanning, obligation generation, and expert systems [10]. These approaches use frameworks like LangChain and GPT-4 to address issues like hallucinations and reliability through prompt engineering and human-in-the-loop designs. Whereas useful in general legal domains, these tools frequently lack scalability for domain-specific regulatory contexts, such as IoT compliance. A supplementary work presented by [11] addresses model hallucinations in Chinese legal settings by enhancing LLM training processes and integrating knowledge bases to produce more accurate legal outputs. Similarly, Intelligent Document Processing (IDP) has also benefited from LLM integration, as demonstrated in [12], which uses LLMs to automate complex legal and regulatory text parsing. Although effective in structured industries such as law and finance, such approaches frequently lack the adaptability required for IoT-specific contexts, where data privacy compliance spans multiple lifecycles and necessitates reasoning about dynamic conditions. Reference [13] explores the application of LLMs, such as ChatGPT, in business management, focusing on their ability to interpret and comply with regulations and legal requirements while addressing ethical and data privacy concerns. Reference [14] investigates LLMs' use in the legal domain by examining algorithms and frameworks designed for automating question answering in legal contexts. It evaluates the strengths and weaknesses of LLMs in understanding and applying legal texts, reasoning through complex legal issues, and predicting judicial outcomes. The survey highlights the potential of LLMs to enhance legal processes while underscoring their limitations in areas such as accuracy, explainability, and contextual reasoning.

B. KGs FOR REGULATORY INFORMATION

A KG represents human knowledge in graph theory, enabling a machine to assimilate its semantic content [15]. It is a method of representing knowledge through graphs so that machines can answer meaningful queries by executing reasoning and inference operations on the resultant KG [15]. This research

represents a KG as $G = (V, E, L, R)$, where G denotes the graph, V represents the nodes (entities or attributes), E are the labeled edges indicating relationships or properties, L are the labels, and R the set of relations. Each edge within the graph is expressed as a triple (h, r, t) , with h and t denoting the head and tail entities, respectively, and r signifying the relationship between them. Every triple represents an assertion by intuition. However, assertions can also be considered facts F , provided that the KG was constructed accurately and precisely using a reliable data source. Domain-specific KGs contain concepts and relationships between them. Chemistry [16], finance [17], and medicine [18] are just a few examples of domains that have established KGs. This work references the IoT regulatory domain comprehensive KG, *IoT-Reg* [6].

Introducing KGs in the legal and regulatory sectors represents a major progression in tackling the issues related to IoT data privacy and compliance. Reference [19] presents a framework for developing an ontology for the National Institute of Standards and Technology Interagency Report (NISTIR) 8228 standard. This approach integrates Natural Language Processing and Semantic Web concepts to ensure IoT wearable devices adhere to NIST controls and mitigate privacy risks. Similarly, [20] proposes a semantically rich, machine-processable KG that captures various data compliance regulations as they apply to cloud data, thus automating an organization's data compliance processes and assisting the proactive detection of data breaches. In a complementary effort, [6] introduces the *IoT-Reg* KG, a comprehensive framework combining various data privacy and security regulations, which this work references. This stratified approach addresses multiple stages of the IoT data lifecycle and converts regulatory controls into seamlessly integrated system components that prioritize risk management and compliance. These studies highlight the transformative potential of KGs in legal and regulatory domains, illustrating their capacity to streamline compliance processes, deliver detailed data-handling strategies, and ensure consistent adherence to regulations across the diverse IoT domain.

C. INTEGRATING LLMs WITH STRUCTURED KNOWLEDGE SOURCES

Reference [7] presents a comprehensive roadmap for integrating LLMs and KGs, highlighting their combined potential to enhance knowledge representation, reasoning, and interpretability. They propose three noteworthy frameworks: KG-enhanced LLMs, LLM-augmented KGs, and synergized LLMs + KGs, each of which aims to leverage the strengths of both technologies to overcome their respective limitations. This roadmap suggests a promising direction for research in making LLMs more knowledgeable and interpretable by embedding structured knowledge bases into their architecture. This study fits into the KG-enhanced LLM framework, which embeds structured knowledge into LLM architectures and enables them to reason with external knowledge bases. This integration allows for a more

refined understanding and application of vast information repositories, which is especially important for IoT regulatory compliance. Notable advancements in this domain include *JointLK* and *KagNet* frameworks that showcase the potential of integrating LLMs and KGs to improve commonsense reasoning and knowledge-based decision-making. *KagNet*, introduced by [21], investigates Knowledge-Aware Graph Networks that enrich LLM outputs with contextually relevant information from KGs, emphasizing the potential for such integrations to improve understanding of complex queries. On the other hand, [22] introduces *JointLK*, a framework for joint reasoning with LLMs and KGs that provides insights into how this collaboration can improve question-answering accuracy by leveraging the structured knowledge embedded in KGs. These studies highlight the potential for combining LLMs' linguistic prowess with the factual precision of KGs, paving the way for novel applications in IoT regulatory compliance. For instance, the *PrivComp-KG* framework, proposed by [23], integrates LLMs with a privacy policy compliance KG to verify organizational adherence to privacy regulations such as GDPR. The system aligns privacy policies with relevant regulatory sections by leveraging Retrieval-Augmented Generation (RAG) and a structured KG, providing dynamic compliance insights. This is consistent with our framework's goal of combining structured knowledge and linguistic interpretability, further enhanced by incorporating deontic logic for IoT-specific compliance. Reference [24] describes a method for improving the accuracy of LLMs by incorporating deterministic factual knowledge during the pre-training phase. This method uses an external knowledge source to improve the models' performance in tasks that require factual precision. Likewise, [25] describes the development of *QA-GNN*, a model that combines the capabilities of LLMs and KGs using graph neural networks. This method significantly improves question-answering performance and demonstrates the potential of combining LLMs and structured knowledge for complex reasoning tasks. Reference [26] introduces Reasoning on Graphs (RoG), a framework that integrates LLMs and KGs for faithful and interpretable reasoning. RoG employs planning, retrieval, and reasoning steps to generate relational pathways from KGs to guide reasoning. This guarantees that LLMs use current information and structural direction while augmenting their reasoning capabilities.

D. CHALLENGES IN AUTOMATED COMPLIANCE SYSTEMS

Given the interdisciplinary perspective of this work, there are challenges with automated compliance systems that have been examined. Reference [27] presents a cutting-edge approach to ensuring GDPR compliance for IoT devices using blockchain and smart contracts. This methodology aims to automate the verification process and improve data privacy and user trust by keeping an immutable ledger of data transactions. They highlight blockchain technology's potential to provide a transparent and auditable system for GDPR compliance and propose a scalable solution that could

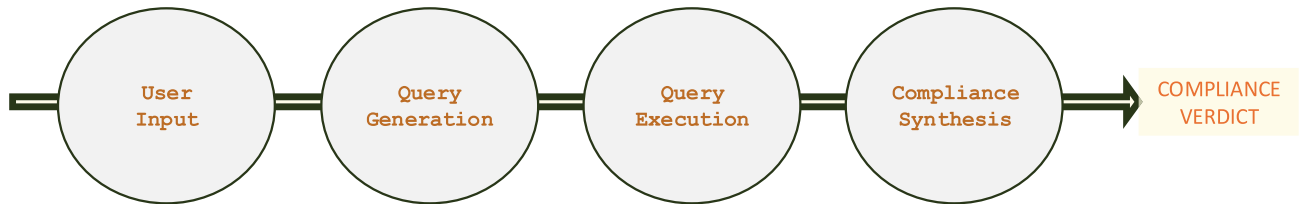


FIGURE 1. The user-generated input (natural language queries) is passed to the LLM for query generation. The LLM outputs a structured query that is executed against the KG to retrieve regulatory information. The results are then fed into the compliance synthesis module, which outputs regulatory advice or flags violations.

transform how IoT devices adhere to privacy regulations. Also, [28] explores the architectural, engineering, and construction (AEC) sectors, and examines how integrating Building Information Modeling (BIM) and knowledge representation standards could improve automated compliance checking (ACC). Their study emphasizes the challenges in quality assurance and control within ACC processes and highlights the need for ongoing enhancement in digital compliance systems. Although focused on AEC, their findings on integrating structured standards are relevant to IoT compliance frameworks. Reference [29] examines the challenges of automating compliance checking for building regulations as they focus on rule interpretation and representation. They highlight problems stemming from the imprecise nature of legal terminology in building codes and emphasize the need for advanced natural language processing and knowledge representation techniques. Their study showcases the disparity between existing technical capabilities and the goal of full automation as they call for artificial intelligence (AI) and machine learning advancements to bridge this divide.

III. METHODOLOGY

A. SYSTEM OVERVIEW

We have created a framework that integrates an LLM and a KG to automate regulatory compliance checks, focusing on the IoT data lifecycle. Our framework dynamically adapts to evolving regulations while supporting automated compliance verification via natural language queries.

At a high level, our system comprises four core components: user input, query generation, KG-based query execution, and compliance synthesis, as illustrated in Fig. 1.

- **User Input:** The system starts with user-generated natural language queries. These inputs typically inquire about data handling activities' adherence to regulatory frameworks. For example, users may inquire whether a data-sharing activity complies with privacy laws.
- **Query Generation:** A fine-tuned LLM processes the natural language query and generates a structured SPARQL (SPARQL query language) query tailored to the context of the question. The LLM, trained on a curated dataset of compliance queries, is adept at identifying regulatory elements (including obligations, permissions, prohibitions, and dispensations) and mapping them to corresponding KG entities. For deontic queries, the

LLM's SPARQL generation targets specific deontic elements—obligations, permissions, or prohibitions—within the KG. In contrast, non-deontic queries retrieve general regulatory data from the KG without applying deontic constraints.

- **Query Execution:** The generated query is run against the *IoT-Reg* KG, which models the relationships between IoT devices, data handling activities, and relevant regulatory controls we developed in previous work [6]. The KG, stored in a SPARQL endpoint, captures the entire IoT data lifecycle by mapping different data handling activities to regulatory obligations, permissions, prohibitions, and dispensations.
- **Compliance Synthesis:** The compliance synthesis module processes the KG results. This module interprets the query results in light of regulatory requirements and offers actionable compliance advice. The module ensures the system correctly determines whether an activity complies with applicable regulations and flags potential violations.

B. KG DESIGN

We adopted the comprehensive *IoT-Reg* KG from our prior work to model the intricate relationships between IoT data handling activities and regulatory obligations. This KG is fundamental to our framework's ability to capture the entire lifecycle of IoT data, from collection to deletion. We facilitate compliance verification across various IoT use cases by structuring these activities around critical regulatory controls.

1) ONTOLOGY AND STRUCTURE

We build our KG with semantic web technologies, specifically RDF and OWL. These provide a flexible framework for modeling relationships between IoT entities and legal obligations. The ontology contains:

- **IoT Entities:** These are the primary players in IoT ecosystems, including devices, data types, users, and activities. For example, the KG models a wearable device that collects personal health data, which can then be shared with healthcare providers under specific regulatory constraints.
- **Regulatory Controls:** We model regulatory controls, such as obligations, permissions, prohibitions, and dispensations, using classes linked to specific legal frameworks,

such as GDPR. These controls are instantiated as classes, with each legal provision (for example, GDPR Article 5 or Article 6) represented as a single instance linked to IoT activities via object properties such as *hasObligation* and *hasPermission*.

This structure enables our KG to function as a dynamic repository for legal standards and data handling requirements, ensuring adaptability to changing regulations.

2) DEONTIC REASONING

Within the KG, we use deontic logic to formalize the normative aspects of legal regulations, which enables our system to reason about obligations (must-do), permissions (may-do), prohibitions (must-not-do), and dispensations (exceptions). This approach aids legal complexity management and allows our system to navigate compliance scenarios in which IoT activities must meet specific regulatory requirements.

Deontic logic is a branch of logic that deals with normative concepts like obligations, permissions, and prohibitions and has numerous applications in compliance systems. Legal compliance checks can be formalized by representing legal rules and requirements as deontological expressions. Deontic logic captures the essential properties of regulations, such as obligations (what must be done), permissions (what may be done), and prohibitions (what must not be done), allowing systems to determine whether specific actions comply with legal constraints. This approach significantly improves automated reasoning in uncertain legal scenarios, which leads to better decision-making in compliance checks [30].

Integrating deontic logic into knowledge-based systems can help map legal provisions to computable rules and improve the system's regulatory compliance capability. Several frameworks have been proposed, frequently using Semantic Web technologies such as RDF (Resource Description Framework) and OWL (Web Ontology Language) to formally represent standards. A well-studied approach combines deontic logic with defeasible reasoning to manage conflicting norms, exceptions, and dispensations, which permit previously prohibited actions when justified by legal exceptions or public interest considerations. Reference [31] proposes a framework for legal compliance that uses OWL 2's decidable fragments, which extends the system's ability to reason over complex regulatory environments, especially in business process compliance. However, challenges such as norm conflicts and exceptions still exist, and frameworks like defeasible deontic logic have been developed to prioritize specific norms over others during compliance checks [31], [32].

3) POPULATING THE GRAPH

We populate the *IoT-Reg* KG with synthetic data to test the system's ability to handle real-world compliance challenges, simulating typical IoT scenarios, such as wearable devices

Ontology metrics:	
Metrics	
Axiom	1335
Logical axiom count	862
Declaration axioms count	394
Class count	114
Object property count	78
Data property count	27
Individual count	176

FIGURE 2. Ontology metrics after KG population.

that collect, retain, and share user health data. For instance, smartwatches often process personal health metrics like heart rate, sleep patterns, and physical activity data, subject to GDPR compliance requirements. We use synthetic data to ensure the KG provides robust and scalable compliance verification while avoiding the privacy concerns associated with real-world data. This synthetic population enables us to test the framework under various regulatory scenarios, ensuring it can handle a wide range of personal data-related compliance inquiries. The graph contains 862 logical axioms. See Fig. 2.

4) QUERY EXECUTION

We host the KG on an Apache Jena Fuseki [33] SPARQL endpoint to support real-time query execution. When the LLM generates a query in response to user input, it interacts directly with the KG to retrieve relevant triples representing the relationships between IoT activities and regulatory controls. For example, when a user inquires whether data retention policies comply with legal requirements, the system generates a SPARQL query to determine whether data retention periods meet GDPR obligations. The query engine retrieves the necessary obligations and permissions, playing its role in ensuring the system quickly and accurately provides compliance advice or flags potential violations.

To maintain the currency of the knowledge graph, we use Apache Jena Fuseki's SPARQL Update API to ingest new RDF triples incrementally. To enable our system to remain adaptable and up-to-date as data protection regulations evolve, we are also developing a semi-automated ingestion pipeline that combines machine-assisted parsing of updated regulatory documents with human-in-the-loop review to ensure consistency with our ontology design and GDPR semantics.

Although the *IoT-Reg* ontology models four deontic categories, we use only obligations, prohibitions, and permissions during compliance advice generation in this study. Dispensations typically represent conditional exceptions or context-specific waivers rather than enforceable duties, and their inclusion may introduce interpretive ambiguity into compliance verdicts. We exclude dispensations from the SPARQL query results and the generated compliance advice to maintain clarity, consistency, and practical applicability. In future work, we may explore logic-aware exception handling when context-sensitive interpretability mechanisms are integrated into the pipeline.

C. LLM FINE-TUNING AND SPARQL QUERY GENERATION

1) PARAMETER-EFFICIENT FINE-TUNING

We use Low-Rank Adaptation (LoRA) for Parameter-Efficient Fine-Tuning (PEFT), which allows us to fine-tune a subset of the model without requiring extensive retraining. LoRA improves computational efficiency by freezing most of the model's parameters and only adjusting a few for the task. LoRA incorporates additional low-rank matrices into the model, selectively adjusting certain aspects of the model architecture, preserving the LLM's core knowledge, and reducing computational overhead while allowing task-specific adaptation.

According to [34], LoRA modifies the self-attention mechanism's query matrix within the transformer architecture. For each layer l , the original query matrix Q_l is given by $Q_l \in \mathbb{R}^{m \times d}$, where m represents the number of input tokens and d the dimensionality of the model. LoRA introduces two low-rank matrices $X_l \in \mathbb{R}^{d \times r}$ and $Y_l \in \mathbb{R}^{r \times d}$, where $r \ll \min(m, d)$. The change to the query matrix δQ_l is computed as $\delta Q_l = Q_l X_l Y_l$, where δQ_l has the same dimensionality as Q_l . The output of the self-attention mechanism for layer l is therefore $O_l = \text{Attention}(Q_l + \delta Q_l, K_l, V_l)$, where K_l and V_l are the key and value matrices that remain unchanged during fine-tuning. Adjusting the query matrix Q_l via the low-rank matrices X_l and Y_l efficiently encodes task-specific adaptations into the model. This approach is highly efficient in terms of both computational resources and performance management. According to [35], larger language models have a lower intrinsic dimension, meaning we can tune LLMs on fewer dimensions without losing performance. This property allows us to adapt the Mistral 7B model [36] with minimal parameter adjustments. The ability to fine-tune on fewer dimensions enables us to achieve solid regulatory compliance performance with a reduced risk of overfitting.

2) DATASET FOR FINE-TUNING

- Composition and Curation

We prepare the dataset by pairing each natural language compliance question with a gold standard SPARQL query tailored to our *IoT-Reg* KG. We manually generated the queries with careful domain expertise, which revolved around IoT device usage (a Garmin Smartwatch in this case), user consent, data retention, and permissions grounded in fundamental GDPR norms. We ensure broad coverage of deontic (obligations, prohibitions, permissions) and non-deontic (factual data retrieval) questions to reflect typical regulatory compliance queries. No data normalization or duplicate removal was required, as each query was carefully curated.

- Multi-Query Augmentation

We adopt a multi-query augmentation approach to boost robustness under diverse user phrasings. We extend each base query in the training set with four semantically similar variations to simulate diverse user interactions and enhance robustness in compliance query responses. This multi-query

approach increases the variety and coverage of potential compliance queries, simulating the variability found in real-world scenarios. It broadened the model's exposure to language variety, helping it handle natural language differences while preserving the same underlying SPARQL intent. Our final dataset encompasses 606 training queries, 122 validation queries, and 120 testing queries.

3) SPARQL QUERY GENERATION PROCESS

Given the domain specificity of GDPR queries, the base model lacked the context to produce correct URIs (Uniform Resource Identifier) or domain-appropriate constraints, such as searching for Article_5_1_e or matching particular device KG classes. Fine-tuning injects these domain concepts and typical question forms, enabling the model to generate accurate SPARQL queries aligned with our *IoT-Reg* KG structure. Without this step, the base model guesses unsupported, hallucinated URIs or omits crucial triple patterns. Fine-tuning proved essential for aligning query outputs with regulatory schema expectations. Once fine-tuned, the LLM translates natural language queries to SPARQL queries. Let Q represent the natural language query from the user. The LLM model f processes Q and outputs a SPARQL query S , expressed as $S = f(Q)$. This transformation relies on the model's probability distribution over the SPARQL query structure, represented as $P(S|Q) = f_{\text{SPARQL}}(Q)$. Here, f_{SPARQL} refers to the fine-tuned probability distribution that guides the LLM in selecting specific SPARQL tokens based on the input query. All queries use SPARQL 1.1 syntax and functions, which are broadly supported by major triplestores.

For example, when a user asks, "What personal data is shared with healthcare providers?" The LLM generates a SPARQL query corresponding to the KG's structure. The generated query (excluding prefixes) could look like this:

```
SELECT DISTINCT
(SUBSTR(STR(?data), STRLEN(STR(iot-reg:))+1) AS ?sharedData)
WHERE {
  ?dataSharing a iot-reg:DataSharing ;
  iot-reg:shares ?data ;
  iot-reg:hasRecipient iot-reg:HealthcareProvider .
  ?data iot-reg:isObservedBy ?device .
  FILTER(CONTAINS(STR(?device),
    "Garmin_Smartwatch"))
}
```

4) INCORPORATING DEONTIC LOGIC

This work employs deontic logic to ensure that the KG effectively models and enforces the legal and normative rules governing regulatory compliance, particularly those derived from the GDPR. Deontic logic, which formalizes normative concepts like obligations, permissions, prohibitions, and dispensations, is essential for the system's reasoning about regulatory compliance. We detail how we integrate deontic logic into the KG structure and query execution process.

- Modeling in the KG

Our implementation begins with the *IoT-Reg* KG, which treats GDPR articles as regulatory controls mapped to their corresponding deontic concepts. These mappings allow the

system to identify and reason about legal requirements at various stages of IoT data handling. For each GDPR article, specific deontic properties are attached:

- *Obligations* define mandatory actions for compliance, such as GDPR *Article_5*'s requirement for lawful, fair, and transparent data processing. In the KG, these are mapped using the deontic property *iot-reg:hasObligation*.
- *Permissions* represent actions allowed under specific regulatory conditions, such as GDPR *Article_6*'s lawful bases for data processing (for example, user consent). These are captured in the KG with *iot-reg:hasPermission*.
- *Prohibitions* identify forbidden actions, such as GDPR *Article_9*'s restriction on processing sensitive personal data without meeting specific conditions. This is encoded in the KG with *iot-reg:hasProhibition*.
- *Dispensations* allow for exceptions to prohibitions and are modeled in the KG with *iot-reg:hasDispensation*.

The GDPR Article's corresponding deontic rules are instantiated in the KG using object properties defined above. For example, GDPR Article 5 is represented in the KG as follows:

```
:Article_5 iot-reg:hasObligation :Obligation_Article_5 ;
iot-reg:hasPermission :Permission_Article_5 ;
iot-reg:hasProhibition :Prohibition_Article_5 ;
rdfs:label "GDPR Article 5: Principles Relating
to Processing of Personal Data"
:Obligation_Article_5 rdfs:type iot-reg:Obligation ;
rdfs:label "Data must be processed lawfully,
fairly, and transparently" .
```

- In SPARQL Query

We use deontic labels directly in SPARQL queries generated by the fine-tuned LLM. These queries determine whether specific IoT data lifecycle activities comply with the GDPR's deontic conditions. For example, a query assessing data sharing compliance under GDPR Article 6 looks for associated obligations and permissions to ensure the activity complies with lawful consent or other regulatory requirements. Here is a sample deontic query:

```
PREFIX rdf: <http://www.w3.org/1999/02/22-rdf-syntax-ns#>
PREFIX rdfs: <http://www.w3.org/2000/01/rdf-schema#>
PREFIX iot-reg: <http://knacc.umbc.edu/kelvinechenim/ontologies/iot-reg#>
SELECT DISTINCT
(SUBSTR(STR(?data),STRLEN(STR(iot-reg:))+1) AS ?dataValue)
(SUBSTR(STR(?GdprControl),STRLEN(STR(iot-reg:))+1) AS
?GdprControlValue)
?obligationLabel
WHERE {
?dataSharing rdf:type iot-reg:DataSharing ;
iot-reg:shares ?data ;
iot-reg:hasRegulatoryControls ?GdprControl .
?GdprControl iot-reg:hasObligation ?obligation .
?obligation rdfs:label ?obligationLabel .
FILTER(CONTAINS(STR(?obligationLabel), "consent"))
}
```

This query retrieves all data-sharing activities and user consent-related obligations.

- With LLM for Compliance

The LLM is responsible for dynamically generating SPARQL queries based on user input. It also correlates natural language compliance questions with specific deontic concepts found in the KG. This enables real-time compliance checks

that ensure data-handling activities meet their obligations or are flagged as potential violations. For example, when a user inquires whether Garmin smartwatches comply with data retention obligations under GDPR *Article_5*, the LLM generates a SPARQL query that checks whether the data retention periods meet the lawful basis requirements while ensuring compliance with storage limitation rules.

```
SELECT DISTINCT
(SUBSTR(STR(?data),STRLEN(STR(iot-reg:))+1) AS ?dataValue)
(SUBSTR(STR(?GdprControl),STRLEN(STR(iot-reg:))+1) AS
?GdprControlValue)
?retentionPeriod
?obligationLabel
WHERE {
?dataRetention a iot-reg:DataRetention ;
iot-reg:retains ?data .
?data iot-reg:hasRetentionPeriod ?retentionPeriod .
?dataRetention iot-reg:hasRegulatoryControls
?GdprControl .
?GdprControl iot-reg:hasObligation ?obligation ;
rdfs:label ?GdprControlLabel .
?obligation rdfs:label ?obligationLabel .
FILTER(CONTAINS(STR(?GdprControlLabel), "Storage
limitation"))
}
```

The system can meet factual and normative requirements by adding deontic logic to the LLM's query generation.

D. COMPLIANCE SYNTHESIS

The Compliance Synthesis Module is critical for generating actionable regulatory advice based on SPARQL query results obtained from the KG. It ensures that regulatory information, such as obligations, permissions, and prohibitions, is effectively communicated to the LLM. After receiving the SPARQL query results, the module preprocesses them into a format that the LLM can interpret. This entails structuring the data in a concise, human-readable format while adhering to the LLM's input requirements. The module incorporates deontic logic into the LLM's task through prompt engineering, ensuring that the generated compliance advice accurately reflects the regulatory framework. This integration enables the module to provide compliance advice that is both legally sound and grounded on factual data retrieved from the KG.

The *IoT-Reg* KG encodes these deontic concepts as properties linked to specific regulatory articles. Each regulatory subclass (such as GDPR Article 6) is modeled with its obligations, permissions, and prohibitions. For instance, the KG may include obligations related to data retention periods, prohibitions on unauthorized data sharing, and permissions for processing under legal exemptions. This structured representation allows this module to dynamically assess whether IoT data lifecycle activities meet or violate regulatory requirements. The compliance synthesis process uses data retrieved from the KG, populated with structured, factual information relating to IoT data handling and regulatory requirements. Non-deontic queries retrieve only factual data (implying a straightforward information retrieval) relevant to the query without deontic categorization. For example, a non-deontic query like "Which personal data is collected by all devices?" yields a factual list of data types collected by each device. In contrast, deontic queries retrieve

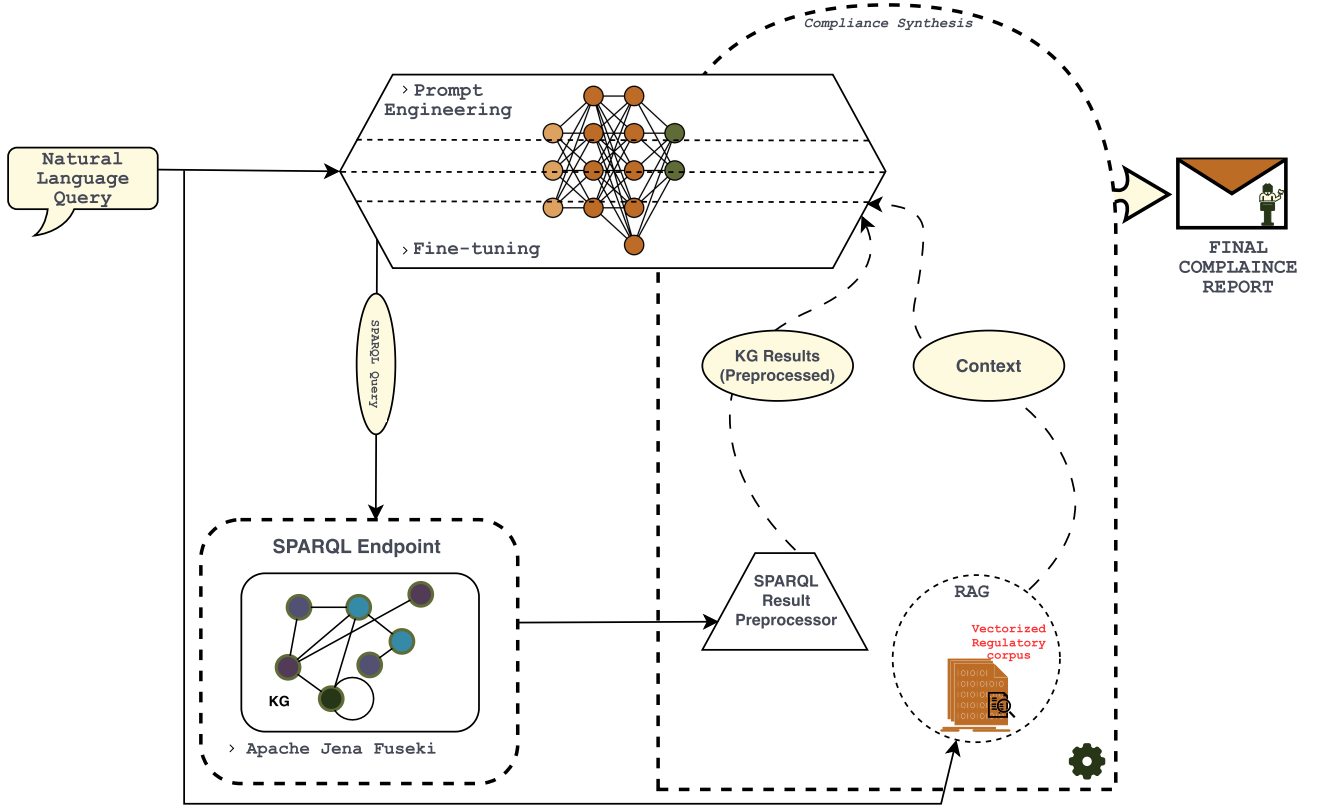


FIGURE 3. Fact-based compliance framework integrating the domain-specific KG with a fine-tuned LLM.

regulatory permissions, obligations, and prohibitions mapped to corresponding GDPR articles.

We use a tailored prompt engineering approach to ensure that the LLM-generated responses are consistent with this deontic logic framework. The prompt explicitly instructs the LLM to structure its output around the deontic elements of the compliance process. Each LLM-generated response includes obligations fulfilled based on the SPARQL query results, permissions granted for the data-handling activity, and flagging of any violations of prohibitions.

This module uses a hybrid of SPARQL-driven KG retrievals and Retrieval-Augmented Generation (RAG) techniques. Each query initially triggers a SPARQL command that targets the KG to extract pertinent compliance data. Subsequently, for additional context, the system employs LlamaIndex [37], a document retrieval framework, to source supplementary compliance information from an indexed repository of regulatory documents. During the retrieval process, chunks of the regulatory document d_i relevant to the query Q are selected based on a similarity threshold τ . A subset $D_q \subseteq D$ corresponding to the retrieved context is defined as:

$$D_q = \{d_i \in D \mid \text{sim}(Q, d_i) \geq \tau\}, \quad |D_q| = k \quad (1)$$

where k denotes the fixed number of retrieved document chunks.

Combining KG-based data with contextual insights from external documents ensures that compliance responses are

nuanced and up-to-date. This layered methodology is essential for deontic queries requiring complex regulatory references, while strengthening the model's interpretive depth and accuracy.

The compliance outcome C integrates the user query Q , structured *IoT-Reg* KG results R_G (which may include deontic or non-deontic elements), and the retrieved regulatory context D_q from the RAG component. These three inputs are combined into a prompt and passed to the LLM to produce multiple candidate compliance advice responses. We define this generative process using a function g , where:

$$\{C_1, C_2, \dots, C_N\} = g(Q, R_G, D_q) \quad (2)$$

Here, g denotes the compliance generation function that synthesizes responses conditioned on both structured and unstructured evidence sources.

Each candidate C_i is embedded using a lightweight sentence transformer, and its semantic alignment is computed with respect to the embedding of the combined generation prompt, which includes the natural language query Q , the retrieved legal segments D_q , and the SPARQL-derived KG results R_G . The similarity score is computed as:

$$S(C_i) = \text{sim}(e(C_i), e(\text{prompt}(Q, R_G, D_q))) \quad (3)$$

The final compliance output C is selected by maximizing the alignment score:

$$C = \arg \max_{C_i} S(C_i) \quad (4)$$

This process ensures that the generated compliance advice is semantically grounded in both structured KG facts and up-to-date legal references, reducing hallucination risk and enhancing interpretability. Fig. 3 illustrates our compliance framework.

Dispensations often represent conditional exceptions rather than strict requirements, and adding them to compliance instructions may introduce ambiguity. We structure the compliance advice around the other actionable and enforceable deontological elements (obligations, permissions, and prohibitions), excluding dispensations from the final report to keep the compliance advice clear and directly applicable to regulatory requirements. The module outputs a compliance verdict (Fig. 4) that classifies the data-handling activities as one of the following:

- Compliant: All obligations are met, and no prohibitions are violated.
- Non-compliant: Obligations are unmet, or prohibitions are violated.
- Conditionally compliant: The activity is permitted under specific conditions, but additional actions may be required to satisfy legal requirements fully.

E. GENERALIZABILITY TO OTHER FRAMEWORKS

Our compliance architecture is modular and extensible. Despite its focus on the GDPR, the *IoT-Reg* KG can incorporate new privacy laws by defining classes and relations that reflect domain-specific obligations. For instance, the California Consumer Privacy Act (CCPA) introduces concepts such as opt-out rights and do-not-sell requests, whereas the Health Insurance Portability and Accountability Act (HIPAA) focuses on protected health information. The LLM component can be fine-tuned or prompted with examples referencing provisions from these additional frameworks. Although regulations like CCPA emphasize concepts not present in the GDPR (for example, household data), integrating structured KG elements with retrieval-augmented LLMs remains valid. These frameworks introduce modeling differences, and supporting multiple regulations may eventually require a bridging ontology or harmonization layer [38]. Future work may extend this architecture to include partial HIPAA and the NISTIR 8228 standard mappings.

IV. EXPERIMENTAL SETUP

In this study, we locally fine-tune an existing base model, Mistral-7B-Instruct-v0.2, to optimize it for regulatory compliance tasks. This fine-tuning process ensures the model generates structured SPARQL queries from natural language input, particularly for IoT data handling. We fine-tune it on a local machine with an Apple M2 Pro chip, 16GB of memory, and macOS 14.6.1. We opt for a local fine-tuning

approach to keep the fine-tuning process contained, allowing for complete control over data privacy and system behavior. Given the sensitive nature of regulatory data, this decision also addresses security concerns about cloud-based training environments [39].

Our fine-tuning dataset includes a diverse range of compliance queries to capture the breadth of GDPR-related themes, spanning the IoT data lifecycle stages and specific obligations, permissions, prohibitions, and exceptions under GDPR Articles to expose the model to varied question types and regulatory contexts. This dataset enhances the LLM's adaptability to deontic and non-deontic queries. This allows it to handle regulatory inquiries ranging from general data facts to complex compliance requirements.

Our optimization parameters include a learning rate of (1×10^{-5}) , 10 epochs, a batch size of 32, 16 LoRA layers, and quantization to reduce memory overhead. This parameter set choice allows efficient training on a 16GB VRAM machine. This approach enables the LLM to specialize in translating regulatory queries into SPARQL queries while maintaining its general-purpose capabilities and optimizing it for our task.

We chunk each regulatory document into ~ 256 -token segments with a 25-token overlap for the RAG component. These chunks are embedded using the *nlpaueb/legal-bert-base-uncased* model and stored in a vector index. At runtime, the system retrieves the top $k = 3$ most relevant segments with a cosine similarity threshold of 0.5, aligning with common practice in semantic retrieval tasks using SBERT-based embeddings [40]. Regarding the compliance-advice ranking component, the model generates $N = 3$ candidate compliance advice responses for each query. These are embedded using the *all-MiniLM-L6-v2* model and compared against the pooled embedding of the retrieved regulatory context.

V. EVALUATION AND DISCUSSION

Our current pipeline achieves single-query latencies of $\sim 60 - 90$ seconds for compliance advice generation on a local machine with constrained free memory (~ 4 GB available).

- SPARQL query generation averaged ~ 8 seconds, with prompt lengths of ~ 135 tokens and ~ 270 -token outputs generated at ~ 33 tokens per second.
- SPARQL execution remained highly efficient, typically completing within ~ 0.02 to 0.05 seconds via Apache Jena Fuseki.
- The most time-intensive component was compliance advice generation, which involves retrieval-augmented synthesis and ranks candidate responses using contextual regulatory text.

We have not yet performed multi-user concurrency testing, and therefore, scalability under parallel or high-throughput conditions remains a topic for future optimization. Nevertheless, our latency profile is adequate for interactive expert-in-the-loop decision support, internal audits, or low-volume compliance advisory workflows.

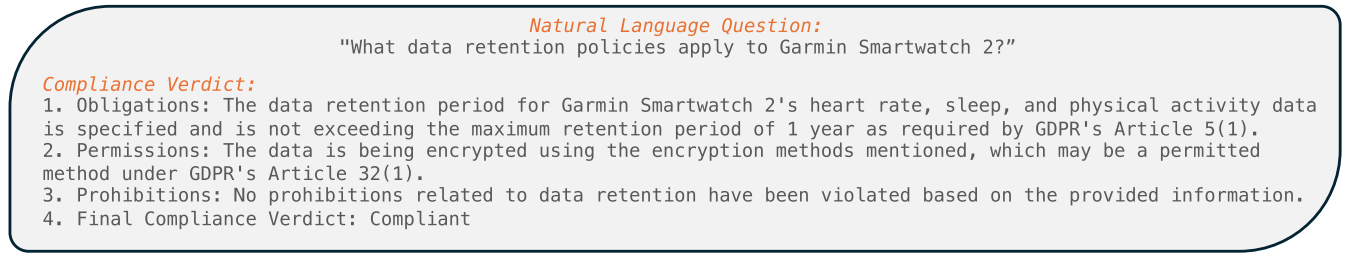


FIGURE 4. Overall outlook of compliance verdict of natural language question grounded in the KG-captured use case.

TABLE 1. Iterative SPARQL Correction Success Rate (50 Queries).

Correction Pass	Cummulative Success Rate	Remaining Failures
Initial Generation	80%	20% (10 queries)
After Pass 2	92%	8% (4 queries)
After Pass 3	100%	0%

A. SPARQL QUERY GENERATION

To assess the LLM's accuracy in generating SPARQL queries from natural language questions, we selected 50 natural language questions from various stages of the IoT data lifecycle. This guaranteed a balanced representation of lifecycle stages such as data collection, processing, sharing, retention, and deletion, all of which are critical compliance concerns for IoT manufacturers under the GDPR. This evaluation aimed to determine the LLM's capacity to construct executable SPARQL queries capable of retrieving correct data from the KG.

In our initial evaluation, we observed that approximately 18% of the generated SPARQL queries contained syntax errors, limiting execution success despite the model's overall competence. We addressed this by implementing a self-correction loop that iteratively refines invalid queries using structured error feedback. Upon reevaluating the 50 representative compliance queries, the exact set of failures varied slightly due to the probabilistic nature of generation, with 10 queries exhibiting syntax errors at initial generation. Of the 40 syntactically valid queries, 37 matched the expected results based on gold-standard SPARQL. The invalid queries (due to syntax and prefix-related errors) were automatically passed through the correction loop. This observation aligns with prior findings, such as in [41], where the authors report that the primary source of SPARQL generation errors often stems from incorrect or hallucinated URIs. At each pass, the model was re-prompted with (a) the original natural language question, (b) the previously generated SPARQL query, and (c) the exact syntax error returned by the RDFlib parser. This error-aware re-prompting enabled the model to refine its output until it passed syntactic validation progressively. All 10 failed queries were repaired within three iterations, resulting in 100% syntactic validity by the third pass (100%@pass3). Table 1 summarizes the cumulative correction success across iterations.

After completing the debugging loop, 41 of the 50 queries produced semantically correct results based on their alignment with gold-standard SPARQL outputs, reflecting a modest improvement over the initial 37. This increase confirms that syntax repair recovered several previously semantically invalid queries due to structural errors. The iterative debugging mechanism effectively eliminates syntax-level failures while preserving the original semantic intent. In future work, we plan to extend this refinement strategy to address semantic mismatches and incomplete triple patterns, which constitute issues that typically arise in more complex queries involving deontic reasoning, such as those related to data processing and consent verification.

B. HUMAN VALIDATION AND REVIEW

To reinforce the reliability of our manually crafted, gold-standard compliance advice, we conducted an independent validation process involving three colleagues experienced in GDPR compliance research. Each reviewer received a set of 50 sample queries identical to those used in our evaluation, the LLM-generated (post-synthesis) compliance advice, the manual (gold-standard) compliance advice, and the corresponding preprocessed KG results for reference. To quantify reviewer judgments, we adopted a five-dimensional rubric, each on a scale of 1 to 5:

Factual Accuracy: Does the LLM response align with the GDPR requirements in question?

Regulatory Completeness: Does it capture the relevant obligations, permissions, prohibitions, and verdict?

Clarity & Conciseness: Is the answer well-structured and understandable?

Alignment with Manual Advice: How closely does the LLM output match the human-written baseline?

Verdict Trustworthiness: Is the final compliance verdict logically justified?

We summarize the results of these 50 queries in Tables 2 and 3.

On average, the human validators rated 84% of the LLM-generated outputs fully or mostly correct, indicating strong domain alignment. The remaining 16% included minor inaccuracies (referencing the right article but missing a short sub-clause) or significant inaccuracies, such as misapplying a special consent requirement. We also note that no single query

TABLE 2. Summary of reviewer validation results (50 queries).

Score (Remark)	Query Count	Sample Issue
5(Excellent)	18	Perfect alignment in both obligations and final verdict
4(Mostly Good)	24	Minor detail missing, but correct overall compliance conclusion
3(Moderate)	5	Omits one or two obligations or references incomplete article
2 or 1 (Poor)	3	Incorrect mapping to GDPR text or contradictory advice

TABLE 3. Mean and standard deviation values computed across the 50 queries, with dimension-specific scoring aligned to the categorical validation breakdown shown in Table 2.

Dimension	Mean Score	Standard Deviation
Factual Accuracy	3.99	0.47
Regulatory Completeness	3.91	0.52
Clarity & Conciseness	4.18	0.39
Alignment with Baseline	4.03	0.56
Verdict Trustworthiness	4.14	0.47

scored consistently low across all five metrics, suggesting the errors tend to be localized rather than systemic.

Reviewers assessed the correctness of the LLM-generated advice, noted any discrepancies between the LLM-generated and manual advice, and offered suggestions for improvement or general feedback on quality. This peer validation step ensured the gold-standard data was carefully reviewed to provide a solid and practical basis for comparing the LLM and manual compliance advice sets.

C. COMPLIANCE ADVICE GENERATION

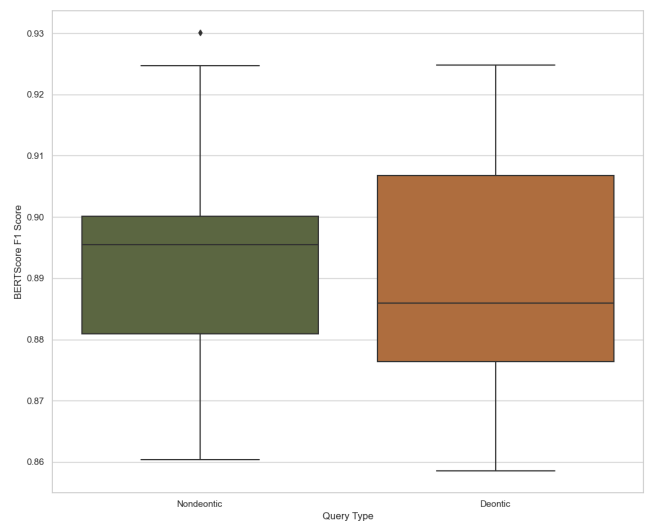
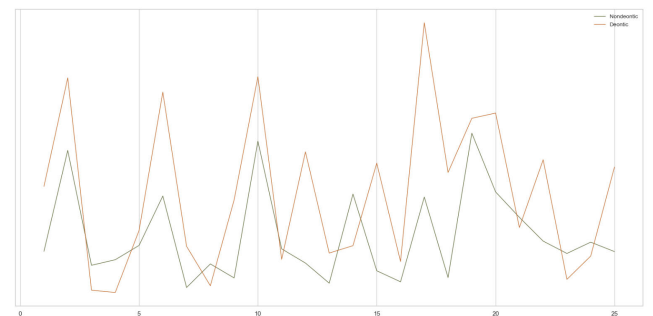
Building on the SPARQL query generation, we assessed the LLM's performance in generating compliance advice by comparing the LLM-generated compliance advice to the gold-standard compliance advice for the 50 successfully executed queries. We used BERTScore—a semantic similarity metric based on Bidirectional Encoder Representations from Transformers (BERT) contextual embeddings [42]—to evaluate the alignment between the two advice sets.

The 50 queries were evenly categorized into regular and deontic, with 25 apiece. The regular ones do not include explicit deontological expressions, while the deontic queries use deontic language and concern obligations, permissions, and prohibitions.

BERTScore metrics were computed at the query level, averaging token-level similarity across the entire compliance advice output for each query. The average BERTScore F1 for non-deontic and deontic queries was 0.8960 and 0.8855, respectively. We performed a t-test to determine whether the difference in mean BERTScore F1 scores between standard and deontic queries was statistically significant. We obtained a p-value of 0.5323, indicating no statistically significant difference between the two groups at a standard 0.05 alpha. However, the deontic queries have a slightly lower mean BERTScore F1 and a broader interquartile range, indicating

TABLE 4. Queries with the highest BERTScore F1 Scores.

User Query	BERTScore_F1	Deontic/Non-Deontic
Which devices collect data without a governing privacy policy at the data collection stage?	0.9301	Non-deontic
Which data collection activities lack defined purposes and permissions required by GDPR?	0.9249	Deontic
What consent has been given for heart rate monitoring on Garmin Smartwatch1 under GDPR?	0.9247	Deontic

**FIGURE 5.** Distribution of BERTScore F1 scores by query type.**FIGURE 6.** Plot of compliance advice generation time vs. normalized query number for the 25 nondeontic and 25 deontic queries. Despite minor variations, the overall trends are closely aligned, reinforcing that query type has no statistically significant effect on generation latency.

more variability in the LLM's performance on these queries (see Figure 5). This suggests that the LLM may have more challenges generating compliance advice for complex deontic logic queries.

High scores indicate that the LLM accurately captures the key compliance elements in these queries. Queries that are more straightforward or closely aligned with gold-standard GDPR requirements typically perform better.

TABLE 5. Average BERTScore metrics across all 50 queries.

Precision	Recall	F1-Score
0.8711	0.9117	0.8908

Table 1 illustrates the average score across the 50 queries. The high scores indicate a solid semantic similarity between the LLM-generated and standard advice, suggesting the system is generally effective in producing accurate compliance guidance, with an average BERTScore F1 score of 0.8908.

Due to the system's predefined structured verdict output, which remains consistent regardless of query type, our system is also generalizable across query types. It does not introduce additional processing complexities by incorporating normative logic (obligations, permissions, or prohibitions). Notably, compliance generation times remain comparable between deontic and non-deontic queries, supporting this uniformity in processing (see Fig. 6). Combined with our empirical observation that the mean BERTScore F1 scores between deontic and non-deontic queries showed no statistically significant difference, these findings affirm the system's stability across varied compliance reasoning tasks.

Our system supports transparency and traceability by maintaining structured audit logs at each step of the compliance pipeline. When a natural language query is submitted, we log the corresponding SPARQL query, the *IoT-Reg* KG results (including obligations, permissions, and prohibitions), and the final textual advice generated by the LLM. These logs provide a clear audit trail showing how each verdict is derived. This chain-of-evidence logging bolsters transparency by making each compliance outcome verifiable and reproducible. Compliance officers can trace verdicts back to (a) specific KG facts, (b) deontic constructs retrieved, and (c) LLM transformations, thereby ensuring accountability and auditability throughout the system.

VI. CHALLENGES AND FUTURE WORK

We used deontic expressions in some training queries to guide the LLM toward more precise compliance advice, especially regarding normative aspects of regulation. Whereas the average BERTScore F1 for deontic queries was slightly lower, further statistical analysis revealed no significant difference between deontic and non-deontic subsets. However, the broader interquartile range in deontic scores suggests a more considerable variance, possibly due to the complexity and ambiguity of legal language, highlighting an area for potential refinement - the LLM's ability to consistently handle nuanced obligations and prohibitions through targeted fine-tuning or domain-specific legal instruction.

The system generates GDPR compliance advice reliably (for both deontic and non-deontic queries) but has some limitations. Non-deontic queries return factual data without specific deontic categorization, potentially limiting the scope of compliance advice for users seeking subtle regulatory insights.

However, the RAG component of our framework addresses this limitation. Furthermore, the model's reliance on synthetic KG data may impact its generalizability to real-world compliance queries. In future expansions, we intend to incorporate partial real data streams, such as anonymized logs or openly available IoT event data, to improve ecological validity. We also plan to link external APIs that fetch up-to-date references to compliance documents or real IoT usage metrics. Future work could also involve fine-tuning the model to improve its adaptability to multifaceted queries and integrating real-world data sources for enhanced authenticity in the compliance synthesis process.

A. AUTOMATION VERSUS HUMAN OVERSIGHT

Our framework is a decision-support system that automates first-pass compliance checks and surfaces relevant obligations or prohibitions. It does not replace human legal experts. Ambiguous regulatory contexts, especially those involving overlapping obligations or novel regulatory amendments, still require a human-in-the-loop for final interpretation. The synergy between automated retrieval/generation and expert validation ensures compliance advice remains efficient and legally robust. Our structured evaluation demonstrates that just as the LLM often generates accurate guidance, human oversight is still essential to ensure comprehensive compliance, mitigate missed details, and handle emergent or ambiguous legal scenarios.

B. HANDLING CONFLICTS AND EXCEPTIONS

Our current framework identifies obligations, permissions, and prohibitions for IoT data handling under the GDPR and flags compliance issues accordingly. However, we acknowledge that real-world regulations often involve exceptions or dispensations that can override otherwise strict prohibitions, creating potential conflicts among obligations (for example, data retention vs. data minimization). If our system detects both an obligation and a conflicting prohibition, we retrieve both but do not automatically resolve which provision takes precedence. Instead, we label such scenarios as "Conditionally Compliant" and recommend human-in-the-loop review, especially if the situation involves multiple overlapping GDPR articles. For example, Article 9's restrictions on processing special categories of data can be overridden by explicit user consent, creating a partial exemption that our pipeline currently highlights without fully deciding the outcome. Whereas this approach maintains transparency, future work will explore advanced reasoning layers such as defeasible deontic logic, norm prioritization, or exception-aware rule modeling, to enable automated conflict resolution, handling partial compliance states and multi-article conflicts more rigorously, allowing the system to track references to potentially conflicting obligations and systematically rank or merge them based on established legal hierarchies. We aim to offer a more comprehensive resolution mechanism for nuanced legal reasoning in IoT compliance workflows by incorporating these expansions in future iterations.

In previous research, we developed a compliance framework centered on risk mitigation for IoT devices using the NISTIR 8228 standard, which provides guidelines for managing IoT cybersecurity and privacy risks [19]. It addressed IoT compliance from a risk-based perspective, focusing on IoT devices that collect and process sensitive personal information. Future work will explore integrating this risk-focused framework with the current GDPR-based model to provide a more holistic and explainable compliance solution applicable across multiple regulatory domains relevant to IoT security and privacy.

VII. CONCLUSION

This work presents an integrated framework that leverages a domain-specific KG and a fine-tuned LLM to provide regulatory compliance advice, focusing on GDPR requirements for IoT devices. This framework enables IoT manufacturers to query compliance issues in natural language and receive actionable advice grounded in regulatory obligations, permissions, and prohibitions. The KG serves as the foundation for structured compliance data that allows the system to map queries to relevant regulatory standards across the data lifecycle.

Our evaluation indicates that the system performs well across deontic and non-deontic queries, achieving high semantic similarity scores between LLM-generated and validated gold-standard advice. Non-deontic queries, which retrieve factual data from the KG without deontic categorization, support straightforward information requests. In contrast, deontic queries benefit from a layered approach, combining KG data with contextual regulatory insights sourced via RAG. This hybrid methodology addresses the interpretative demands of compliance queries, ensuring advice remains accurate, relevant, and contextually aware.

By combining the interpretative power of LLMs with the structured precision of KGs, our framework represents a promising advance in regulatory compliance automation, providing scalable, near-real-time support to IoT manufacturers traversing challenging regulatory environments.

REFERENCES

- [1] W. Li, T. Yigitcanlar, I. Erol, and A. Liu, "Motivations, barriers and risks of smart home adoption: From systematic literature review to conceptual framework," *Energy Res. Social Sci.*, vol. 80, Oct. 2021, Art. no. 102211.
- [2] European Parliament and Council of the European Union. *Regulation (EU) 2016/679 of the European Parliament and of the Council*. [Online]. Available: <https://data.europa.eu/eli/reg/2016/679/oj>
- [3] H. Zhao, H. Chen, F. Yang, N. Liu, H. Deng, H. Cai, S. Wang, D. Yin, and M. Du, "Explainability for large language models: A survey," *ACM Trans. Intell. Syst. Technol.*, vol. 15, no. 2, pp. 1–38, Apr. 2024.
- [4] A. Algaba, C. Mazijn, V. Holst, F. Tori, S. Wenmackers, and V. Ginis, "Large language models reflect human citation patterns with a heightened citation bias," in *Proc. Findings Assoc. Comput. Linguistics: NAACL*. Albuquerque, New Mexico: Association for Computational Linguistics, Apr. 2025, pp. 6829–6864. [Online]. Available: <https://aclanthology.org/2025.findings-naacl.381/>
- [5] S. Ji, S. Pan, E. Cambria, P. Marttinen, and P. S. Yu, "A survey on knowledge graphs: Representation, acquisition, and applications," *IEEE Trans. Neural Netw. Learn. Syst.*, vol. 33, no. 2, pp. 494–514, Feb. 2022.
- [6] K. U. Echenim and K. P. Joshi, "IoT-reg: A comprehensive knowledge graph for real-time IoT data privacy compliance," in *Proc. IEEE Int. Conf. Big Data (BigData)*, Dec. 2023, pp. 2897–2906.
- [7] S. Pan, L. Luo, Y. Wang, C. Chen, J. Wang, and X. Wu, "Unifying large language models and knowledge graphs: A roadmap," *IEEE Trans. Knowl. Data Eng.*, vol. 36, no. 7, pp. 3580–3599, Jul. 2024.
- [8] A. Vaswani, N. Shazeer, N. Parmar, J. Uszkoreit, L. Jones, A. N. Gomez, Ł. Kaiser, and I. Polosukhin, "Attention is all you need," in *Proc. Adv. Neural Inf. Process. Syst.*, vol. 30, Jun. 2017, pp. 5998–6008.
- [9] Y. Bengio, R. Ducharme, and P. Vincent, "A neural probabilistic language model," in *Proc. Adv. Neural Inf. Process. Syst.*, vol. 13, 2000, pp. 932–968.
- [10] J. Ioannidis, J. Harper, M. S. Quah, and D. Hunter, "Gracenote. Ai: Legal generative AI for regulatory compliance," in *AI and Intelligent Assistance for Legal Professionals in the Digital Workplace* (CEUR Workshop Proceedings), vol. 3423, J. G. Conrad et al., Eds., CEUR-WS.org, 2023, pp. 20–31. [Online]. Available: <https://ceur-ws.org/Vol-3423/paper-03.pdf>
- [11] J. Cui, Z. Li, Y. Yang, B. Chen, and Y. Li, "ChatLaw: Open-source legal large language model with integrated external knowledge bases," 2023, *arXiv:2306.16092*
- [12] S. Mandvikar, "Augmenting intelligent document processing (IDP) workflows with contemporary large language models (LLMs)," *Int. J. Comput. Trends Technol.*, vol. 71, no. 10, pp. 80–91, Oct. 2023.
- [13] S. Baier, S.-J. Köchling, and M. Mirbabaie, "Generative AI and the future of work: A multilevel analysis of challenges and opportunities," *J. Management Inf. Syst.*, vol. 40, no. 4, pp. 961–997, Jan. 2024, doi: [10.1080/07421222.2023.2296181](https://doi.org/10.1080/07421222.2023.2296181).
- [14] X. Yang, Z. Wang, Q. Wang, K. Wei, K. Zhang, and J. Shi, "Large language models for automated Q&A involving legal documents: A survey on algorithms, frameworks and applications," *Int. J. Web Inf. Syst.*, vol. 20, no. 4, pp. 413–435, Jul. 2024.
- [15] M. Kejrwal, *Domain-specific Knowledge Graph Construction* (Springer-Briefs in Computer Science). Cham, Switzerland: Springer, 2019.
- [16] F. Farazi, M. Salamanca, S. Mosbach, J. Akroyd, A. Eibeck, L. K. Aditya, A. Chazynski, K. Pan, X. Zhou, S. Zhang, M. Q. Lim, and M. Kraft, "Knowledge graph approach to combustion chemistry and interoperability," *ACS Omega*, vol. 5, no. 29, pp. 18342–18348, Jul. 2020.
- [17] Y. Liu, Q. Zeng, J. O. Meré, and H. Yang, "Anticipating stock market of the renowned companies: A knowledge graph approach," *Complexity*, vol. 2019, no. 1, pp. 1–15, Jan. 2019.
- [18] O. Bodenreider, "The unified medical language system (UMLS): Integrating biomedical terminology," *Nucleic Acids Res.*, vol. 32, no. 1, pp. D267–D270, Jan. 2004.
- [19] K. U. Echenim, L. Elluri, and K. P. Joshi, "Ensuring privacy policy compliance of wearables with IoT regulations," in *Proc. 5th IEEE Int. Conf. Trust, Privacy Secur. Intell. Syst. Appl. (TPS-ISA)*, Nov. 2023, pp. 247–256.
- [20] K. P. Joshi, L. Elluri, and A. Nagar, "An integrated knowledge graph to automate cloud data compliance," *IEEE Access*, vol. 8, pp. 148541–148555, 2020.
- [21] B. Y. Lin, X. Chen, J. Chen, and X. Ren, "KagNet: Knowledge-aware graph networks for commonsense reasoning," in *Proc. 2019 Conf. Empirical Methods Natural Lang. Process. 9th Int. Joint Conf. Natural Lang. Process. (EMNLP-IJCNLP)*, K. Inui, J. Jiang, V. Ng, and X. Wan, Eds., Hong Kong, Association for Computational Linguistics, Nov. 2019, pp. 2829–2839. [Online]. Available: <https://aclanthology.org/D19-1282/>
- [22] Y. Sun, Q. Shi, L. Qi, and Y. Zhang, "JointLK: Joint reasoning with language models and knowledge graphs for commonsense question answering," in *Proc. Conf. North Amer. Chapter Assoc. Comput. Linguistics: Human Lang. Technol.*, M. Carpuat, M.-C. de Marneffe, and I. V. Meza Ruiz, Eds., Seattle, WA, USA: Association for Computational Linguistics, Jul. 2022, pp. 5049–5060. [Online]. Available: <https://aclanthology.org/2022.naacl-main.372/>
- [23] L. Garza, L. Elluri, A. Piplai, A. Kotal, D. Gupta, and A. Joshi, "PrivCompKG: Leveraging KG and LLM for compliance verification," in *Proc. IEEE 6th Int. Conf. Trust, Privacy Secur. Intell. Syst., Appl. (TPS-ISA)*, Oct. 2024, pp. 97–106.
- [24] S. Li, X. Li, L. Shang, C. Sun, B. Liu, Z. Ji, X. Jiang, and Q. Liu, "Pre-training language models with deterministic factual knowledge," in *Proc. Conf. Empirical Methods Natural Lang. Process.*, 2022, pp. 11118–11131.
- [25] M. Yasunaga, H. Ren, A. Bosselut, P. Liang, and J. Leskovec, "QA-GNN: Reasoning with language models and knowledge graphs for question answering," in *Proc. Conf. North Amer. Chapter Assoc. Comput. Linguistics: Human Lang. Technol.*, Jan. 2021, pp. 535–546. [Online]. Available: <https://aclanthology.org/2021.naacl-main.45/>

- [26] L. Luo, Y.-F. Li, G. Haffari, and S. Pan, "Reasoning on graphs: Faithful and interpretable large language model reasoning," in *Proc. 12th Int. Conf. Learn. Represent.*, 2024.
- [27] M. Barati, O. Rana, I. Petri, and G. Theodorakopoulos, "GDPR compliance verification in Internet of Things," *IEEE Access*, vol. 8, pp. 119697–119709, 2020.
- [28] R. Amor and J. Dimyadi, "The promise of automated compliance checking," *Develop. Built Environ.*, vol. 5, Mar. 2021, Art. no. 100039.
- [29] Z. Zhang, L. Ma, and T. Broyd, "Towards fully-automated code compliance checking of building regulations: Challenges for rule interpretation and representation," in *Proc. Eur. Conf. Comput. Construct.*, Jul. 2022.
- [30] A. Dimishkovska, "Deontic logic and legal rules," in *Encyclopedia of the Philosophy of Law and Social Philosophy*, M. Sellers and S. Kirste, Eds., Dordrecht, The Netherlands: Springer, 2017, doi: doi: [10.1007/978-94-007-6730-0_12-2](https://doi.org/10.1007/978-94-007-6730-0_12-2).
- [31] E. Francesconi and G. Governatori, "Patterns for legal compliance checking in a decidable framework of linked open data," *Artif. Intell. Law*, vol. 31, no. 3, pp. 445–464, Sep. 2023.
- [32] F. Cuppens, C. Garion, G. Piolle, and N. Cuppens-Boulahia, "Norms and deontic logic," in *A Guided Tour of Artificial Intelligence Research: Volume I: Knowledge Representation, Reasoning and Learning*, P. Marquis, O. Papini, and H. Prade, Eds., Cham, Switzerland: Springer, 2020, pp. 253–274, doi: doi: [10.1007/978-3-030-06166-5_9](https://doi.org/10.1007/978-3-030-06166-5_9).
- [33] Apache Jena. *Apache Software Foundation*. Accessed: Jan. 1, 2025. [Online]. Available: <https://jena.apache.org/>
- [34] E. J. Hu, Y. Shen, P. Wallis, Z. Allen-Zhu, Y. Li, S. Wang, L. Wang and W. Chen, "LoRA: Low-rank adaptation of large language models," in *Proc. Int. Conf. Learn. Represent.*, 2022. [Online]. Available: <https://openreview.net/forum?id=nZeVKeeFYf9>
- [35] A. Aghajanyan, L. Zettlemoyer, and S. Gupta, "Intrinsic dimensionality explains the effectiveness of language model fine-tuning," 2020, *arXiv:2012.13255*.
- [36] A. Q. Jiang, A. Sablayrolles, A. Mensch, C. Bamford, D. S. Chaplot, D. d. l. Casas, F. Bressand, G. Lengyel, G. Lample, L. Saulnier, L. R. Lavaud, M.-A. Lachaux, P. Stock, T. L. Scao, T. Lavril, T. J. Wang, T. Lacroix, and W. E. Sayed, "Mistral 7B," 2023, *arXiv:2310.06825*.
- [37] J. Liu. (Nov. 2022). *LlamaIndex*. [Online]. Available: https://github.com/jerryliu/llama_index
- [38] F. A. Zaccarini, A. Sarkar, E. Ghedini, and I. M. Paponetti, "Bridge-concepts: Establishing harmonized networks of ontologies," in *Proc. 14th Int. Conf. Formal Ontology Inf. Syst.*, 2024, pp. 1–13.
- [39] N. Soveizi, F. Turkmen, and D. Karastoyanova, "Security and privacy concerns in cloud-based scientific and business workflows: A systematic review," *Future Gener. Comput. Syst.*, vol. 148, pp. 184–200, Nov. 2023.
- [40] N. Reimers and I. Gurevych, "Sentence-BERT: Sentence embeddings using Siamese BERT-networks," in *Proc. Conf. Empirical Methods Natural Lang. Process. 9th Int. Joint Conf. Natural Lang. Process. (EMNLP-IJCNLP)*, Hong Kong: Association for Computational Linguistics, 2019, pp. 3982–3992. [Online]. Available: <https://aclanthology.org/D19-1410/>
- [41] P. A. K. K. Diallo, S. Reynd, and A. Zouaq, "A comprehensive evaluation of neural SPARQL query generation from natural language questions," *IEEE Access*, vol. 12, pp. 125057–125078, 2024.
- [42] T. Zhang, V. Kishore, F. Wu, K. Q. Weinberger, and Y. Artzi, "BERTScore: Evaluating text generation with BERT," in *Proc. ICLR*, 2020.



KELVIN U. ECHENIM (Graduate Student Member, IEEE) received the B.Eng. degree in electrical/electronic engineering from the University of Benin, Nigeria, and the M.B.A. degree in business administration from Delta State University, Nigeria. He is currently pursuing the Ph.D. degree in information systems with the University of Maryland, Baltimore, USA. Before academia, he had over a decade of industry experience, holding roles in engineering and analytics at a

leading telecommunications company. His research interests include the IoT data privacy, KGs, natural language processing, and semantic technologies. He is also a member of ACM and ISC2 and holds several professional certifications.



KARUNA P. JOSHI (Senior Member, IEEE) received the Bachelor of Engineering degree in Computers from the University of Mumbai, and the M.S. and Ph.D. degrees in computer science from UMBC. She is currently a Professor of information systems and the UMBC Director of the Center for Accelerated Real Time Analytics (CARTA). She is also the Director of the Knowledge, Analytics, Cognitive and Cloud (KnACC) Laboratory. She teaches courses in data analytics, big data, database

design, and software engineering. She also has extensive experience working in the industry, primarily as the IT Program/Project Manager of the International Monetary Fund. Her research interests include AI/data science, legal text analytics, cloud computing, and healthcare IT, and she has published over 90 articles. She has been awarded research grants by NSF, ONR, DoD, DHS, Cisco, and GE Research. She was twice awarded the IBM Ph.D. Fellowship by UMBC.

...